JWT 게시판 구현 보고서

01 서비스 소개와 구현 범위

학번 [작성] 이름: [작성] 제출일: [작성]

서비스 이름 : IT 시스템 장애·트러블슈팅 기록 게시판

기술 조합과 버전 React 19.3.0 / Vite 8.3.4 / Spring Boot 3.5.16 / SQLite JDBC 3.51.3.0 / JJWT 0.13.0; Windows 25H2 / Node.js 24.11.1 / npm 11.6.2 / Java 17.0.20.1

GitHub 저장소 URL [작성]

소스 코드 기준 [브랜치 / 코드 구현 기준 커밋 ID 를 기록할 수 있습니다. 최종 제출 기준 커밋 SHA 는 LMS 에 제출합니다.]

이 서비스는 개발자와 시스템 운영자가 서버 오류/장애의 발생 환경, 증상, 원인 분석, 해결 방법을 기록하고 공유하는 게시판이다. 비슷한 장애를 겪었을 때 기존 글의 제목·본문·작성자를 검색해 사례를 찾는다. 본문에는 발생 환경·증상 및 에러 로그·원인 분석·해결 방법을 기록한다. 로그인 없이 목록과 존재하는 글을 조회할 수 있으며 정상 응답은 200 이다.

로그인 상태/에러 배너/목록과 상세 화면 갱신을 컴포넌트 상태로 나누기 위해 React 를 선택했다. JdbcTemplate 의 SQL 실행과 JJWT 의 토큰 발급/검증 흐름을 코드에서 제어하기 위해 Spring Boot 를 선택했다. 제공 템플릿의 게시판 CRUD·SQLite 저장/PBKDF2 검증은 유지했다. AuthService.java 와 frontend-react/src/api.js 의 인증 미완성 부분에 AI 작성 코드를 반영했다. main.jsx 와 style.css 의 화면을 변경하고 BoardController.java 의 fields()에서 비밀번호 원문 길이를 검사하도록 수정했다. 입력 제한을 위반한 응답은 400 BAD_INPUT 이다.

기능	완료 여부	관련 파일	비고 또는 제한
공개 목록과 상세	완료	BoardController.java 의 list()·get(), PostStore.java 의 list()·get()	공식 검사의 무토큰 목록/상세 조회 200; 비로그인 화면의 기존 글 표시
로그인과 JWT 발급	완료	BoardController.java 의 login(), Users.java 의 verify(), AuthService.java 의 issueToken()	정상 로그인 200, Alice 정보·expiresIn 90·가린 토큰 캡처; 잘못된 비밀번호/없는 이메일 각각 401 INVALID_CREDENTIALS
인증과 내 정보 조회	완료	AuthService.java 의 currentUserId()·verifiedUserId(), BoardController.java 의 me()	Alice ID 1·Bob ID 2; 무토큰 401 TOKEN_REQUIRED, 변조 401 INVALID_TOKEN, 만료 401 TOKEN_EXPIRED

기능	완료 여부	관련 파일	비고 또는 제한
본인 글 작성·수정·삭제	완료	BoardController.java 의 create()·update()·delete(), AuthService.java 의 assertOwner()	본인 등록 201/수정 200/삭제 204; Bob 의 Alice 글 수정/삭제 각각 403 FORBIDDEN, 거부 후 재조회 일치
만료·로그아웃·오류 표시	완료	frontend-react/src/api.js 의 request()·clearSession(), main.jsx 의 run()	공백 제목 400 BAD_INPUT; 만료 뒤 로그인 해제; 로그아웃 후 Bearer 헤더 없는 내 정보 요청 401 TOKEN_REQUIRED
DB 데이터 유지	완료	DatabaseConfig.java 의 dataSource(), PostStore.java, schema.sql	서버 재실행 후 5 번 글 제목·본문·작성자 유지, 재조회 200

구조와 변경 내역

브라우저에서 4173 번 preview 화면을 연다. frontend-react/src/api.js 의 request()가 /api 로 요청한다. frontend-react/vite.config.js 의 preview.proxy 가 요청을 8000 번 Spring Boot 로 전달한다. Spring MVC 가 BoardController.java 의 매핑된 메서드를 호출한다. 게시글은 PostStore.java 가 JdbcTemplate 으로 SQLite 의 posts 테이블을 조회하며 정상 조회 응답은 200 이다.

login()은 POST /api/auth/login 으로 email·password 를 전송한다. BoardController.java 의 fields()가 입력을 검사하고 Users.java 의 verify()가 계정을 확인한다. AuthService.java 의 issueToken()이 토큰을 발급한다. 응답을 받은 api.js 의 모듈 변수는 session = { accessToken: data.accessToken, user: data.user }로 바뀐다.

authorizationHeaders()는 session.accessToken 이 있으면 Authorization: Bearer <JWT>를 만든다. request()가 fetch()의 headers 에 이 값을 넣는다. /api/me 와 글 등록·수정·삭제에 사용하며, 로그인 상태의 공개 조회에도 같은 헤더가 붙는다. 보호 API 에 Bearer 헤더가 없거나 형식이 맞지 않으면 401 TOKEN_REQUIRED 이다.

main.jsx 의 save()가 api.update()를 호출하면 PUT /api/posts/{id}로 title·content 를 보낸다. 정상 ID 와 정상 JSON 기준으로 BoardController.java 의 update()는 인증 → 글 조회 → assertOwner() → fields() → DB 변경 순서로 실행한다. PostStore.java 의 update()는 title·content·updated_at 만 바꾼다. 정상 수정은 200, 작성자 불일치는 403 FORBIDDEN 이다.

토큰은 api.js 의 모듈 변수 session 에 저장한다. localStorage 와 sessionStorage 에는 기록하지 않는다. 로그아웃·401 응답·새로고침 이후에는 session = { accessToken: "", user: null }이 된다.

Java 파일 기준 경로: backend-spring/src/main/java/edu/classroom/board/

변경한 파일과 함수	제공 코드의 원래 역할	내가 변경한 내용	변경 이유
AuthService.java 생성자·issueToken()·currentUserId()·verifiedUserId()·assertOwner()	발급 501, 고정 ID 1, 권한 검사 미완성	Codex 작성 코드 반영. 키·HS256·서명·클레임·계정·작성자 검사 추가. 로그인·만료와 수업 공식 검사 도구 실행은 직접 수행	인증 오류 401, 타인 변경 403 FORBIDDEN
BoardController.java 의 fields()	공백 제거 후 길이 검사, 비밀번호 반환값은 원문	Codex 수정 코드 반영. 비밀번호 길이 검사를 원문 기준으로 변경; CRUD·라우트 유지	원문 128 자 초과 400 BAD_INPUT
frontend-react/src/api.js 의 login()·authorizationHeaders()·request()·canEdit()	API 공통 호출·204 처리, 인증 연결 미완성	Codex 작성·수정 코드 반영. session 저장·Bearer 첨부·401 해제·작성자 비교·오류 문구 추가. 제공 코드의 204 분기는 유지	401 이면 session 초기화, 403 이면 유지
frontend-react/src/main.jsx 의 run()·save()·이벤트	로그인 폼·게시판·실패 입력 유지	Codex 수정 코드 반영. 비로그인 저장 차단·프로필과 수정 상태 정리·404 목록 갱신·e.status/e.code 표시. 기존 실패 입력 유지	공백 제목 요청 후 입력 유지, 400 BAD_INPUT

변경한 파일과 함수	제공 코드의 원래 역할	내가 변경한 내용	변경 이유
frontend-react/의 src/main.jsx·src/style.css·index.html·package.json·package-lock.json	기본 화면·제목·의존성	Claude Code 의 화면 초안을 반영하고 직접 화면 확인. 목록·상세 분할, 본문 구역·코드 표시, 검색·복사, 글꼴 추가	title·content 요청 필드는 유지; 표시 형식 변경
frontend-react/src/style.css 의 반응형 규칙	화면 스타일	Codex 수정 코드 반영 후 직접 너비 확인. 상단 줄바꿈은 1023px 이하, 목록·상세 세로 배치는 899px 이하	900px 상단 바 줄바꿈, 390px 세로 배치
루트 README.md, 이 보고서	실행 설명·보고서	Codex 문서 작성 후 코드·직접 남긴 결과와 대조	기본 포트·실행 명령·실제 증거 경로 기록

로컬 실행 기록

운영체제와 버전: Windows 11, 버전 25H2(OS 빌드 26200.9457)를 사용했다.

실행 환경 버전: Windows PowerShell 5.1, Node.js 24.11.1, npm 11.6.2, Java 17.0.20.1 을 사용했다.

새 폴더 설치: 별도 폴더에 저장소를 복제한 뒤 프론트엔드 의존성 설치, 빌드, preview 실행과 백엔드 실행을 확인했다. 기존 작업 폴더의 빌드 캡처인 M00-build.png 에는 빌드 시간 274ms 와 종료 코드 0 이 기록되어 있다.

환경설정: JWT_SECRET 에는 64 자리 16 진수 난수를 설정했다. 비밀 키 원문은 보고서에 기록하지 않았다. JWT_ISSUER 는 webservice-class, JWT_AUDIENCE 는 board-api 로 설정했다. 만료 검사 후 복구한 TOKEN_TTL 값은 90 이다.

프론트엔드 설치·빌드·실행: frontend-react/에서 npm.cmd ci, npm.cmd run build, npm.cmd run preview 를 차례로 실행했다. 빌드 종료 후 확인한 $LASTEXITCODE 값은 0 이다.

백엔드 빌드·실행: backend-spring/에서 .\mvnw.cmd package 를 실행했다. 같은 PowerShell 에서 환경변수를 설정한 뒤 java -jar target\jwt-board-1.0.0.jar 로 서버를 실행했다. 백엔드 주소는 http://127.0.0.1:8000 이며, /api/health 조회 결과의 status 는 ok 이다.

SQLite 파일 경로: backend-spring/에서 서버를 실행하면 상대 경로 data/board.sqlite 를 사용한다. 프로젝트 루트 기준 경로는 backend-spring/data/board.sqlite 이다.

4173 번 접속 및 API 연결 확인: 브라우저에서 http://127.0.0.1:4173 에 접속했다. frontend-react/vite.config.js 의 preview.proxy 가 /api 요청을 8000 번 백엔드로 전달한다. 로그인 후 /api/me 에서 계정 정보를 확인했으며, 응답 상태는 200 이다.

서버 재시작 후 데이터 유지: 같은 backend-spring/ 폴더에서 서버를 종료한 뒤 다시 실행했다. M07-1-restart-log.png 에는 서버 재실행 로그가 기록되어 있다. 재시작 후 Alice 의 5 번 글을 조회해 제목, 본문, 작성자가 유지된 것을 확인했다. M07-restart-after.png 의 GET /api/posts/5 응답 상태는 200 이다.

증거 위치: 실행 및 수동 확인 캡처는 docs/evidence/manual/에 저장했다. 빌드는 M00-build.png, 서버 재실행은 M07-1-restart-log.png, 재시작 후 게시글 조회는 M07-restart-after.png 에 기록했다.

웹서비스설계 03

핵심 코드 설명

3 1 로그인과 JWT 발급

파일 / 함수: backend-spring/src/main/java/edu/classroom/board/BoardController.java 의 login(), AuthService.java 의 issueToken()이다.

코드 발췌

BoardController.java 64~70 행이다.

```
 @PostMapping("/auth/login")
 public Object login(@RequestBody Map<String, Object> body) {
  var input = fields(body, Map.of("email", 254, "password", 128));
  var user = users.verify(input.get("email"), input.get("password"));
  if (user == null) throw new ApiError(401, "INVALID_CREDENTIALS", "이메일 또는 비밀번호를 확인하세요.");
  return Map.of("accessToken", auth.issueToken(user), "expiresIn", ttl, "user", user);
 }
```

코드 발췌: AuthService.java 74~82 행이다.

```
 public String issueToken(Users.PublicUser user) {
  return Jwts.builder()
     .subject(Long.toString(user.id()))
     .issuer(issuer)
     .audience().add(audience).and()
     .expiration(Date.from(Instant.now().plusSeconds(ttl)))
     .signWith(signingKey, Jwts.SIG.HS256)
     .compact();
 }
```

동작과 응답 코드 설명

POST /api/auth/login 은 JSON 본문에서 email 과 password 를 받는다. BoardController.java 의 fields()는 허용되지 않은 필드, 필수 필드 누락, 문자열이 아닌 값, 공백만 있는 값을 거부한다. 이메일은 앞뒤 공백을 제거한 뒤 최대 254 자인지 검사한다. 비밀번호는 앞뒤 공백을 포함한 원문으로 최대 128 자인지 검사한다. 입력 조건을 벗어난 요청의 응답은 400 BAD_INPUT 이다.

입력 검사를 통과하면 Users.java 의 verify()가 이메일에 해당하는 계정을 찾는다. 입력한 비밀번호를 계정의 salt 로 PBKDF2 해시 처리한 뒤 저장된 해시와 비교한다. 계정이 없거나 비밀번호가 일치하지 않으면 user 가 null 이 되며, 응답은 401 INVALID_CREDENTIALS 이다.

계정 확인에 성공하면 AuthService.java 의 issueToken()을 호출한다. 계정 ID 를 문자열로 변환해 sub 에 넣는다. 설정값 issuer 와 audience 는 각각 iss 와 aud 에 넣는다. exp 는 현재 시각에 ttl 초를 더해 설정한다. ttl 은 TOKEN_TTL 환경변수에서 읽으며 기본값은 90 초이다. signWith(signingKey, Jwts.SIG.HS256)으로 서명한 토큰을 문자열로 반환한다. 로그인 응답 본문에는 accessToken, expiresIn, user 가 포함되며 응답 상태는 200 이다.

3 2 브라우저 토큰 저장과 전송

파일 / 함수: frontend-react/src/api.js 의 login(), authorizationHeaders(), request(), clearSession()이다.

코드 발췌

frontend-react/src/api.js 38~45 행이다.

```
export async function login(email, password) {
  const data = await request("/auth/login", {
    method: "POST",
    body: JSON.stringify({ email, password }),
  });
  session = { accessToken: data.accessToken, user: data.user };
  return data.user;
}
```

같은 파일의 6~10 행이다.

```
function authorizationHeaders() {
  return session.accessToken
    ? { Authorization: `Bearer ${session.accessToken}` }
    : {};
}
```

같은 파일의 request() 내부 20~22 행이다.

```
  const data = response.status === 204 ? null : await response.json();
  if (!response.ok) {
    if (response.status === 401) clearSession();
```

동작과 응답 코드 설명

login()은 이메일과 비밀번호를 JSON 문자열로 변환해 /api/auth/login 으로 전송한다. 로그인에 성공하면 응답의 토큰과 계정 정보를 frontend-react/src/api.js 의 모듈 변수 session 에 저장한다. localStorage 와 sessionStorage 에는 기록하지 않는다. 로그인 성공 후 변수 상태는 session = { accessToken: data.accessToken, user: data.user }이다.

authorizationHeaders()는 session.accessToken 이 있을 때 Authorization: Bearer <JWT> 헤더를 만든다. 토큰이 없으면 빈 객체를 반환한다. request()는 이 객체를 fetch()의 요청 헤더에 합친다. 내 정보 조회와 게시글 등록·수정·삭제 요청도 request()를 거친다. 토큰 없이 /api/me 를 호출했을 때 서버 응답은 401 TOKEN_REQUIRED 이다.

request()는 응답 상태가 204 이면 JSON 을 읽지 않고 data 를 null 로 설정한다. 나머지 응답은 JSON 본문을 읽는다. 실패 응답에서는 HTTP 상태를 error.status, JSON 오류 코드를 error.code 에 넣어 예외를 던진다. 타인 글 수정·삭제에 대한 403 FORBIDDEN 응답에서는 clearSession()을 호출하지 않으므로 session 은 기존 값으로 유지된다.

로그아웃 시에는 clearSession()이 토큰과 계정 정보를 지운다. 서버가 401 을 반환했을 때도 request()가 같은 함수를 호출한다. 토큰 만료는 보호 API 요청에 대한 401 TOKEN_EXPIRED 응답을 받은 뒤 처리한다.
새로고침하면 모듈을 다시 불러오므로 로그인 정보가 초기화된다. 이때 변수 상태는 session = { accessToken: "", user: null }이다.

서버 인증과 작성자 권한

3 3 서버 JWT 검증

파일 / 함수: backend-spring/src/main/java/edu/classroom/board/AuthService.java 의 currentUserId(), verifiedUserId()이다.

코드 발췌

AuthService.java 의 currentUserId() 내부 91~100 행이다.

```
  try {
   try {
    return verifiedUserId(parser.parseSignedClaims(bearer.group(1)).getPayload());
   } catch (ExpiredJwtException e) {
    verifiedUserId(e.getClaims());
    throw new ApiError(401, "TOKEN_EXPIRED", "로그인 시간이 만료되었습니다. 다시 로그인하세요.");
   }
  } catch (JwtException | IllegalArgumentException e) {
   throw new ApiError(401, "INVALID_TOKEN", "유효하지 않은 로그인 정보입니다. 다시 로그인하세요.");
  }
```

같은 파일의 verifiedUserId() 내부 104~111 행이다.

```
  if (!(claims.get("exp") instanceof Number)
     || !issuer.equals(claims.getIssuer())
     || claims.getAudience() == null
     || !claims.getAudience().contains(audience)
     || !(claims.get("sub") instanceof String subject)
     || !subject.matches("[1-9][0-9]*")) {
   throw new ApiError(401, "INVALID_TOKEN", "토큰의 필수 정보를 확인할 수 없습니다.");
  }
```

동작과 응답 코드 설명

currentUserId()는 요청의 Authorization 헤더를 읽는다. BEARER 정규식으로 헤더 형식을 검사한 뒤 토큰 문자열을 추출한다. 헤더가 없거나 Bearer 형식에 맞지 않으면 응답은 401 TOKEN_REQUIRED 이다.

AuthService.java 의 생성자는 verifyWith(signingKey)로 서명 검증 키를 설정한다. 허용 서명 알고리즘은 HS256 으로 제한한다. requireIssuer(issuer)와 requireAudience(audience)로 발급자와 대상 값을 지정한다. currentUserId()의 parser.parseSignedClaims()가 이 설정에 따라 토큰을 검증한다. 서명 변조, 허용하지 않은 알고리즘, 발급자 또는 대상 불일치로 검증에 실패하면 응답은 401 INVALID_TOKEN 이다.

verifiedUserId()는 숫자형 exp, 설정값과 일치하는 iss, 설정된 대상을 포함하는 aud 를 검사한다. sub 는 양의 정수를 나타내는 문자열이어야 한다. 조건을 통과하면 Long.parseLong(subject)로 계정 ID 를 변환한다. 이어서 users.find(userId)로 실제 계정이 있는지 확인한다. 필수 클레임 누락, 값의 형식 오류, ID 변환 실패 또는 존재하지 않는 계정의 응답은 401 INVALID_TOKEN 이다.

만료된 토큰에서 ExpiredJwtException 이 발생하면 verifiedUserId(e.getClaims())를 먼저 호출한다. 나머지 필수 클레임과 계정 존재 검사를 통과한 경우에 만료 오류를 반환한다. 이때 응답은 401 TOKEN_EXPIRED 이다.

모든 검사를 통과하면 currentUserId()는 토큰에서 확인한 계정 ID 를 반환한다. 보호 API 는 이 값을 계정 조회와 작성자 비교에 사용한다. 검증 실패 시 Errors.java 의 api()가 JSON 본문에 code 와 message 를 넣는다. 401 응답에는 WWW-Authenticate: Bearer 헤더를 추가하며 HTTP 상태는 401 이다.

3 4 작성자 권한 검사

파일 / 함수: backend-spring/src/main/java/edu/classroom/board/BoardController.java 의 create(), update(), delete()와 AuthService.java 의 assertOwner()이다.

코드 발췌

BoardController.java 의 update() 97~105 행이다.

```
 @PutMapping("/posts/{id}")
 public Object update(
    @PathVariable String id, @RequestBody Map<String, Object> body, HttpServletRequest req) {
  long user = auth.currentUserId(req), pid = postId(id);
  var p = existing(pid);
  auth.assertOwner(user, p.authorId());
  var input = fields(body, Map.of("title", 100, "content", 5000));
  return store.update(pid, input.get("title"), input.get("content"));
 }
```

같은 파일의 delete() 내부 109~113 행이다.

```
  long user = auth.currentUserId(req), pid = postId(id);
  var p = existing(pid);
  auth.assertOwner(user, p.authorId());
  store.delete(pid);
  return ResponseEntity.noContent().build();
```

AuthService.java 의 assertOwner() 119~123 행이다.

```
 public void assertOwner(long userId, long authorId) {
  if (userId != authorId) {
   throw new ApiError(403, "FORBIDDEN", "본인이 작성한 기록만 수정하거나 삭제할 수 있습니다.");
```

```
  }
}
```

동작과 응답 코드 설명

글 등록 시 create()는 currentUserId()가 반환한 계정 ID 를 store.create()에 전달한다. 작성자 ID 는 이 값으로 결정한다. 요청 본문에서 허용하는 필드는 title 과 content 이다. 본문에 authorId 나 userId 를 추가하면 fields()가 거부하며, 응답은 400 BAD_INPUT 이다.

update()는 토큰 인증을 먼저 수행한다. 인증을 통과하면 postId()로 글 ID 형식을 검사한다. 이어서 existing()으로 글을 조회한다. 양의 정수 형식의 ID 에 해당하는 글이 없으면 응답은 404 NOT_FOUND 이다.

글이 존재하면 assertOwner(user, p.authorId())를 호출한다. 토큰에서 확인한 계정 ID 와 저장된 글의 작성자 ID 를 비교한다. 두 값이 다르면 입력 내용 검사와 DB 수정을 진행하지 않는다. 응답은 403 FORBIDDEN 이다.

작성자 확인을 통과하면 fields()가 제목과 본문을 검사한다. 앞뒤 공백을 제거한 제목은 1~100 자, 본문은 1~5000 자여야 한다. 필드 누락, 문자열이 아닌 값, 공백만 있는 값, 길이 초과 또는 추가 필드는 400 BAD_INPUT 으로 처리한다. 검사를 통과하면 store.update()가 DB 를 수정하며, 응답은 200 이다.

delete()도 인증, 글 ID 형식 검사, 글 조회, 작성자 비교 순서로 처리한다. 작성자가 일치하면 store.delete(pid)로 글을 삭제한다. 삭제 성공 응답은 본문이 없는 204 이다.

401 은 토큰이 없거나 검증에 실패해 요청 계정을 확인할 수 없는 경우이다. 403 은 토큰 인증을 통과했지만 해당 글의 작성자가 아닌 경우이다. frontend-react/src/api.js 의 canEdit()는 수정·삭제 버튼 표시 여부를 결정한다. API 를 직접 호출한 요청에도 서버의 assertOwner()가 실행되므로 타인 글 변경 요청의 응답은 403 FORBIDDEN 이다.

테스트 결과

실행 환경: Windows 11 버전 25H2(OS 빌드 26200.9457), Windows PowerShell 5.1, Node.js 24.11.1, npm 11.6.2, Java 17.0.20.1 을 사용했다. 브라우저는 Google Chrome 을 사용했으며 개발자 도구의 Network 탭에서 요청 헤더와 응답을 확인했다. 백엔드는 backend-spring/에서 .\mvnw.cmd package 후 java -jar target\jwt-board-1.0.0.jar 로 실행했다. 프론트엔드는 frontend-react/에서 npm.cmd ci, npm.cmd run build, npm.cmd run preview 순서로 실행했다.

로컬 배포 확인: 별도 폴더에 저장소를 복제한 뒤 의존성 설치, 프론트엔드 빌드·preview 실행, 백엔드 JAR 실행과 4173 번 접속을 확인했다. 기존 작업 폴더의 빌드 결과는 docs/evidence/manual/M00-build.png 에 기록했으며 종료 코드는 0 이다. http://127.0.0.1:4173 에서 로그인과 게시글 등록·수정·삭제를 확인했다. preview 의 /api 요청은 8000 번 백엔드로 전달되며, 로그인 후 /api/me 의 응답 상태는 200 이다.

테스트 일시 및 코드 버전: 브라우저 수동 확인과 서버 재시작 확인은 2026 년 10 월 15 일에 수행했다. 수업 공식 검사 도구 실행과 로그아웃 후 요청 확인은 2026 년 10 월 16 일에 수행했다. 테스트 기준 코드의 커밋 SHA: (직접 입력).

토큰 TTL: 일반 검사는 TOKEN_TTL=90 으로 실행했다. 만료 검사는 TOKEN_TTL=3 으로 서버를 재시작한 뒤 실행했다. 공식 검사 로그에서 4 초 대기 후 보호 API 요청이 401 TOKEN_EXPIRED 로 거부된 것을 확인했다. 만료 검사 후 복구한 TOKEN_TTL 값은 90 이다.

ID	수행 절차와 사용자	예상 결과	실제 HTTP 와 code	판정	증거
T01	토큰 없이 게시글 목록과 존재하는 글 상세 조회	목록·상세 각각 200	목록 200 / 해당 없음, 상세 200 / 해당 없음. 비로그인 화면에서 기존 글 표시	PASS	M11-check-api-final.log 의 public list·public detail, M05-refresh.png
T02	Alice 계정으로 로그인 후 응답과 요청 헤더 확인	200, JWT 발급·로그인 표시	200 / 해당 없음. 응답에 accessToken·Alice ID 1·expiresIn 90 포함. 후속 요청에 Bearer 헤더 첨부	PASS	M01-login-response-masked.png, M01-1-bearer-request-masked.png, M11-check-api-final.log
T03	잘못된 비밀번호와 존재하지 않는 이메일로 각각 로그인	각각 401 INVALID_CREDENTIALS	두 요청 모두 401 / INVALID_CREDENTIALS	PASS	M11-check-api-final.log 의 wrong password·unknown email
T04	토큰 없이 내 정보 조회와 글 등록 요청	각각 401 TOKEN_REQUIRED	GET /api/me, POST /api/posts 모두 401 / TOKEN_REQUIRED. WWW-Authenticate: Bearer 검사 통과	PASS	M11-check-api-final.log 의 no token me·no token create
T05	Alice 의 정상 토큰으로 글 등록 후 내 정보 조회	등록 201, authorId 1. 내 정보 200, Alice 정보	등록 201 / 해당 없음, authorId 1. 수동 등록 응답의 Location: /api/posts/5 확인. 내 정보 200 / 해당 없음, ID 1	PASS	M02-alice-owner.png, M11-check-api-final.log 의 create post·Alice me

ID	수행 절차와 사용자	예상 결과	실제 HTTP 와 code	판정	증거
T06	Alice 의 정상 토큰으로 본인 글 수정·삭제 후 재조회	수정 200, 삭제 204, 삭제 후 조회 404	수정 200 / 해당 없음, 제목 변경 확인. 삭제 204 / 해당 없음, 빈 본문. 삭제 후 404 / NOT_FOUND	PASS	M02-1-owner-update.png, M11-check-api-final.log 의 owner update·delete owned test post·deleted post missing
T07	Bob 의 정상 토큰으로 Alice 글 수정 후 공개 재조회	403 FORBIDDEN, 원문 유지	PUT 403 / FORBIDDEN. 후속 조회 200 / 해당 없음, 글 전체 필드가 요청 전 값과 일치	PASS	M11-check-api-final.log 의 Bob denied PUT·직후 failed request leaves data unchanged
T08	Bob 의 정상 토큰으로 Alice 글 삭제 후 공개 재조회	403 FORBIDDEN, 글 유지	DELETE 403 / FORBIDDEN. 후속 조회 200 / 해당 없음, 글 전체 필드가 요청 전 값과 일치	PASS	M11-check-api-final.log 의 Bob denied DELETE·직후 failed request leaves data unchanged
T09	토큰 서명 부분의 첫 글자를 바꾼 뒤 내 정보·등록·수정·삭제 요청	네 요청 모두 401 INVALID_TOKEN	GET·POST·PUT·DELETE 모두 401 / INVALID_TOKEN. WWW-Authenticate: Bearer 검사 통과. 기존 글 재조회 결과 일치	PASS	M11-check-api-final.log 의 tampered 4 건·후속 failed request leaves data unchanged, M11-check-api-final.png
T10	TTL 3 초로 토큰 발급 후 4 초 대기. 내 정보·등록·수정·삭제 요청과 브라우저 만료 처리 확인	401 TOKEN_EXPIRED, 로그인 해제·만료 안내	네 API 요청 모두 401 / TOKEN_EXPIRED. 기존 글 재조회 결과 일치. 브라우저에서 만료 안내와 로그인 해제 확인	PASS	M12-check-api-expiry.log, M12-check-api-expiry.png, M08-expired-401.png
T11	로그인 후 로그아웃한 상태에서 내 정보 조회	Authorization 헤더 없음, 401 TOKEN_REQUIRED	GET /api/me 의 401 / TOKEN_REQUIRED. Request headers 에 Authorization 없음. WWW-Authenticate: Bearer 확인	PASS	M13-1-logout-headers.png, M13-1-logout-response.png
T12	Bob 의 글 등록 본문에 authorId: 1 과 userId: 1 을 각각 추가	각각 400 BAD_INPUT	두 추가 필드 요청 모두 400 / BAD_INPUT 으로 등록 거부	PASS	M11-check-api-final.log 의 reject authorId·reject userId
T13	본인 토큰으로 공백 제목·공백 본문·제목 101 자·본문 5001 자 등록 요청. 공백 제목 수정 요청	각각 400 BAD_INPUT	공식 검사의 네 입력 모두 400 / BAD_INPUT. 수동 공백 제목 수정도 400 / BAD_INPUT, 입력 내용과 로그인 상태 유지	PASS	M11-check-api-final.log 의 input validation 4 건, M03-input-400.png

ID	수행 절차와 사용자	예상 결과	실제 HTTP 와 code	판정	증거
T14	없는 양의 정수 ID 조회·수정·삭제와 잘못된 ID 조회. 수정·삭제에는 정상 토큰 사용	없는 글 404 NOT_FOUND, 잘못된 ID 400 BAD_INPUT	ID 9007199254740991 의 GET·PUT·DELETE 모두 404 / NOT_FOUND. ID abc 의 GET 은 400 / BAD_INPUT	PASS	M11-check-api-final.log 의 missing ID·missing protected PUT·missing protected DELETE·bad ID
T15	글 저장 후 서버 프로세스를 종료·재실행한 뒤 기존 글 조회	제목·본문·작성자 유지	5 번 글 재조회 200 / 해당 없음. 재시작 전 제목·본문·작성자 유지	PASS	M07-1-restart-log.png, M07-restart-after.png
T16	로그인한 상태에서 페이지 새로고침 후 기존 글 조회	로그인 해제, 공개 글 유지	화면에 로그아웃 상태 표시, 작성 입력 비활성화. 기존 5 번 글 조회 200 / 해당 없음	PASS	M05-refresh.png
T17	토큰 없이 수정·삭제 요청. Bob 의 정상 토큰으로 본인 글 등록·수정·삭제	무토큰 각각 401 TOKEN_REQUIRED. 본인 작업 201·200·204	무토큰 PUT·DELETE 모두 401 / TOKEN_REQUIRED. Bob 등록 201 / 해당 없음, 수정 200 / 해당 없음, 삭제 204 / 해당 없음, 빈 본문	PASS	M11-check-api-final.log 의 no token PUT·DELETE·Bob own update·삭제 검사, M04-1-bob-create.png, M04-2-bob-update.png, M04-3-bob-delete.png

HTTP 응답 확인 기록

확인 항목	기대 응답	실제 HTTP 와 code	증거 위치
정상 조회·로그인·수정	**200**	공개 목록·상세, 정상 로그인, 내 정보 조회, 본인 글 수정 모두 200 / 해당 없음	M11-check-api-final.log, M01-login-response-masked.png, M02-1-owner-update.png
새 글 등록	**201 및 Location**	201 / 해당 없음. Alice 등록 응답은 Location: /api/posts/5, Bob 등록 응답은 Location: /api/posts/6	M02-alice-owner.png, M04-1-bob-create.png, M11-check-api-final.log
본인 글 삭제	**204 및 빈 본문**	204 / 해당 없음, 빈 본문. 화면에서 삭제한 글이 목록에서 제거됨. 공식 검사의 삭제 후 재조회는 404 / NOT_FOUND	M04-3-bob-delete.png, M11-check-api-final.log
입력 오류·추가 작성자 필드	**400 BAD_INPUT**	공백 제목·본문, 제목 101 자·본문 5001 자, authorId·userId 추가 요청 모두 400 / BAD_INPUT	M03-input-400.png, M11-check-api-final.log 의 input validation·reject authorId·reject userId
잘못된 계정	**401 INVALID_CREDENTIALS**	잘못된 비밀번호와 없는 이메일 요청 모두 401 / INVALID_CREDENTIALS	M11-check-api-final.log 의 wrong password·unknown email
토큰 없음·헤더 형식 오류	**401 TOKEN_REQUIRED**	무토큰 내 정보·등록·수정·삭제 요청 모두 401 / TOKEN_REQUIRED. 헤더 형식 오류는 별도 실행 기록 없이 코드로 확인	M11-check-api-final.log, M13-1-logout-headers.png, M13-1-logout-response.png. 형식 검사는 AuthService.java 의 currentUserId()
변조·클레임 오류	**401 INVALID_TOKEN**	서명 변조 토큰의 내 정보·등록·수정·삭제 요청 모두 401 / INVALID_TOKEN. 개별 클레임 오류는 별도 실행 기록 없이 코드로 확인	M11-check-api-final.log 의 tampered 4 건. 클레임 검사는 AuthService.java 의 생성자·verifiedUserId()

확인 항목	기대 응답	실제 HTTP 와 code	증거 위치
정상 서명의 만료 토큰	**401 TOKEN_EXPIRED**	TTL 3 초 토큰 발급 후 4 초 대기. 내 정보·등록·수정·삭제 요청 모두 401 / TOKEN_EXPIRED	M12-check-api-expiry.log, M12-check-api-expiry.png, M08-expired-401.png
다른 작성자의 변경	**403 FORBIDDEN**	Bob 의 정상 토큰으로 Alice 글 수정·삭제 요청 시 각각 403 / FORBIDDEN. 거부 후 재조회 결과 일치	M11-check-api-final.log 의 Bob denied PUT·Bob denied DELETE·후속 failed request leaves data unchanged
없는 글	**404 NOT_FOUND**	ID 9007199254740991 의 공개 조회와 정상 토큰 수정·삭제 요청 모두 404 / NOT_FOUND	M11-check-api-final.log 의 missing ID·missing protected PUT·missing protected DELETE

공식 검사 도구의 check()는 무토큰·서명 변조·만료 요청에서 HTTP 상태와 JSON code 를 비교한다. 응답의 WWW-Authenticate 값이 Bearer 로 시작하는지도 검사한다. M11·M12 로그에서 해당 검사의 통과를 확인했다. M13-1-logout-headers.png 에서도 로그아웃 후 /api/me 응답의 WWW-Authenticate: Bearer 를 확인했으며 응답은 401 TOKEN_REQUIRED 이다.

M08-expired-401.png 에서 만료 안내와 로그인 해제를 확인했다. M13 두 캡처에서는 로그아웃 상태와 토큰 없는 요청을 확인했다. 403 이후 로그인 유지는 직접 촬영한 화면 대신 frontend-react/src/api.js 의 request() 분기로 확인했다. clearSession()은 응답 상태가 401 일 때만 호출한다. 따라서 403 처리 후 session 은 기존 값으로 유지된다 .

공식 검사 도구의 unchanged()는 변경 요청이 거부된 뒤 공개 GET 으로 같은 글을 다시 조회한다. 조회한 객체 전체를 요청 전 객체와 비교한다. Bob 의 타인 글 수정·삭제 거부, 서명 변조 요청, 만료 요청 이후의 비교가 통과했다. 제목·본문·작성자·시간 필드가 기존 값과 일치했으며 재조회 응답은 200 이다.

정상 토큰으로 없는 글을 수정한 결과는 M11-check-api-final.log 의 missing protected PUT 에서 확인했으며, 실제 응답은 404 NOT_FOUND 이다. 토큰 없이 없는 글을 수정하는 복합 조건은 별도 실행 기록이 없다. BoardController.java 의 update()는 currentUserId()를 existing()보다 먼저 호출한다. 따라서 정상 JSON 과 정상 형식의 ID 를 사용한 무토큰 요청의 코드상 응답은 401 TOKEN_REQUIRED 이다.

Bob 의 정상 토큰으로 Alice 글에 공백 제목을 보내는 복합 조건도 별도 실행 기록이 없다. update()가 assertOwner()를 fields()보다 먼저 호출하므로 코드상 응답은 403 FORBIDDEN 이다. Alice 가 본인 글에 공백 제목을 보낸 결과는 M03-input-400.png 에서 직접 확인했으며, 실제 응답은 400 BAD_INPUT 이다.

테스트 증거

로그인과 토큰 전송

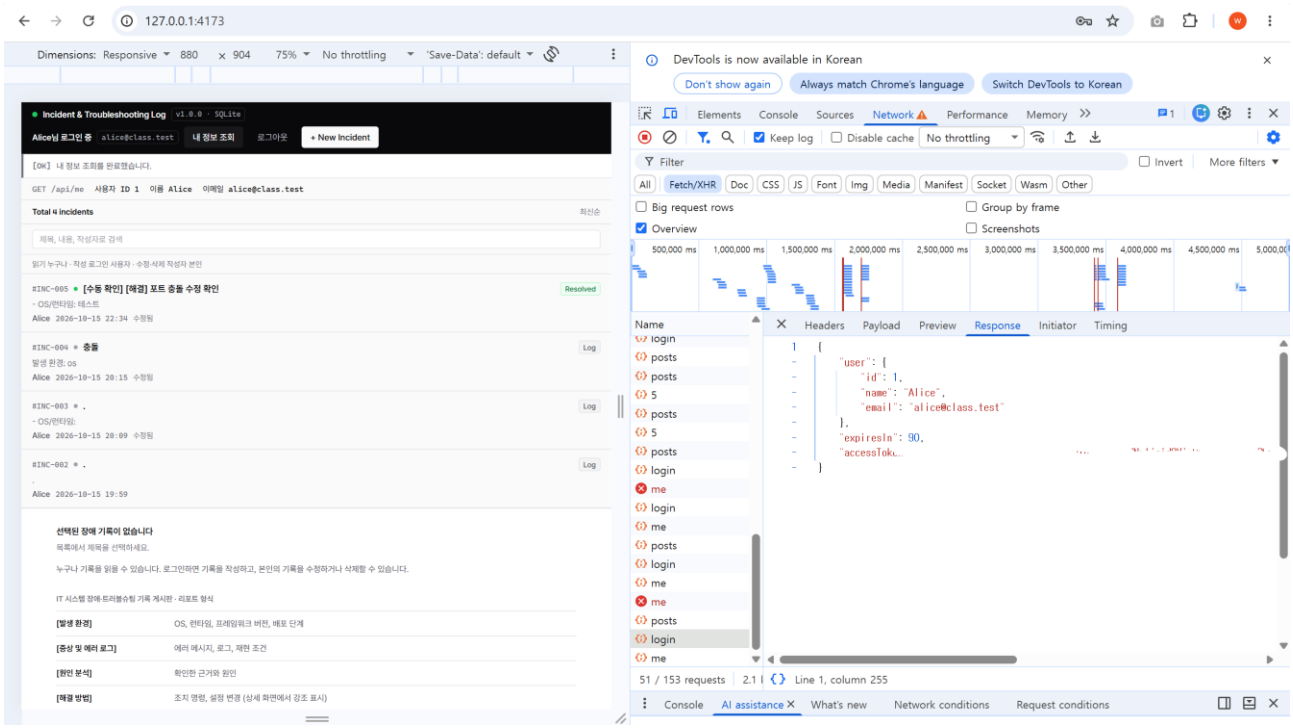


그림 1. T02 — Alice 로그인 성공. 응답 200, expiresIn 90, 토큰 값 마스킹

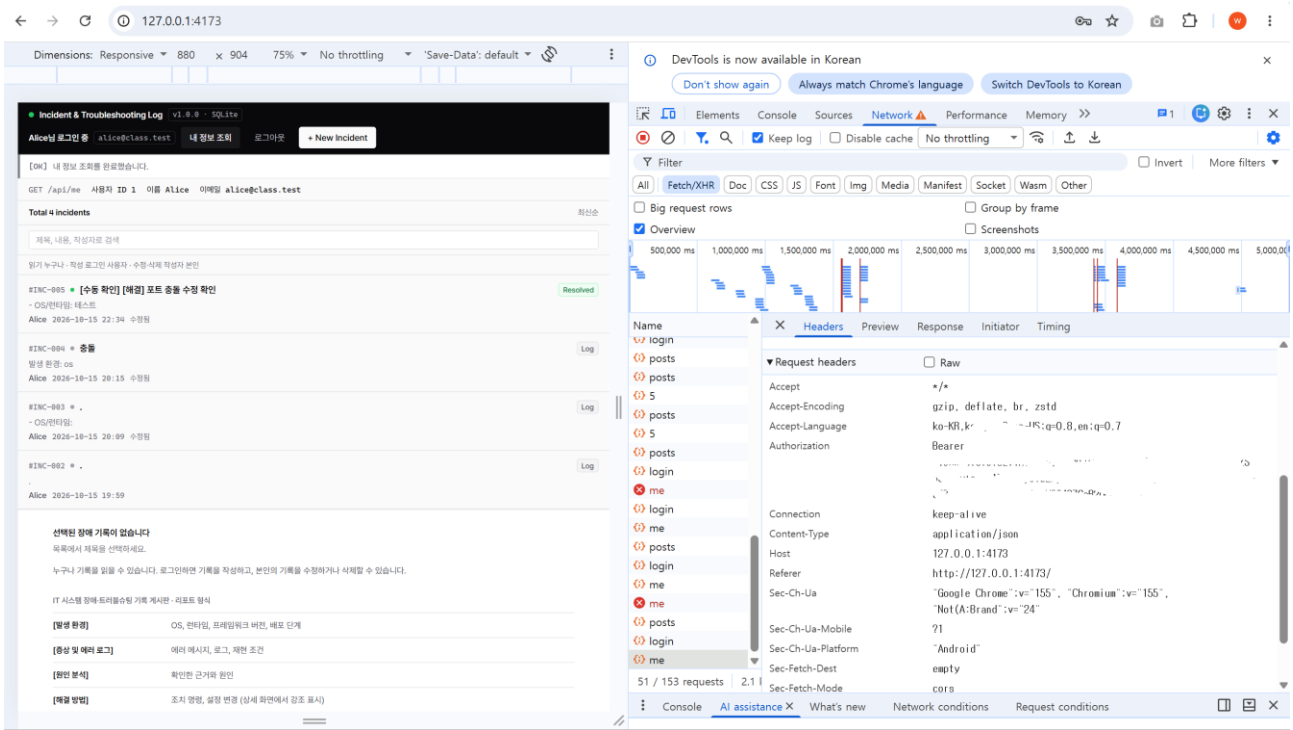


그림 2. T02 — 보호 API 요청의 Authorization: Bearer <JWT> 헤더 확인, 토큰 값 마스킹

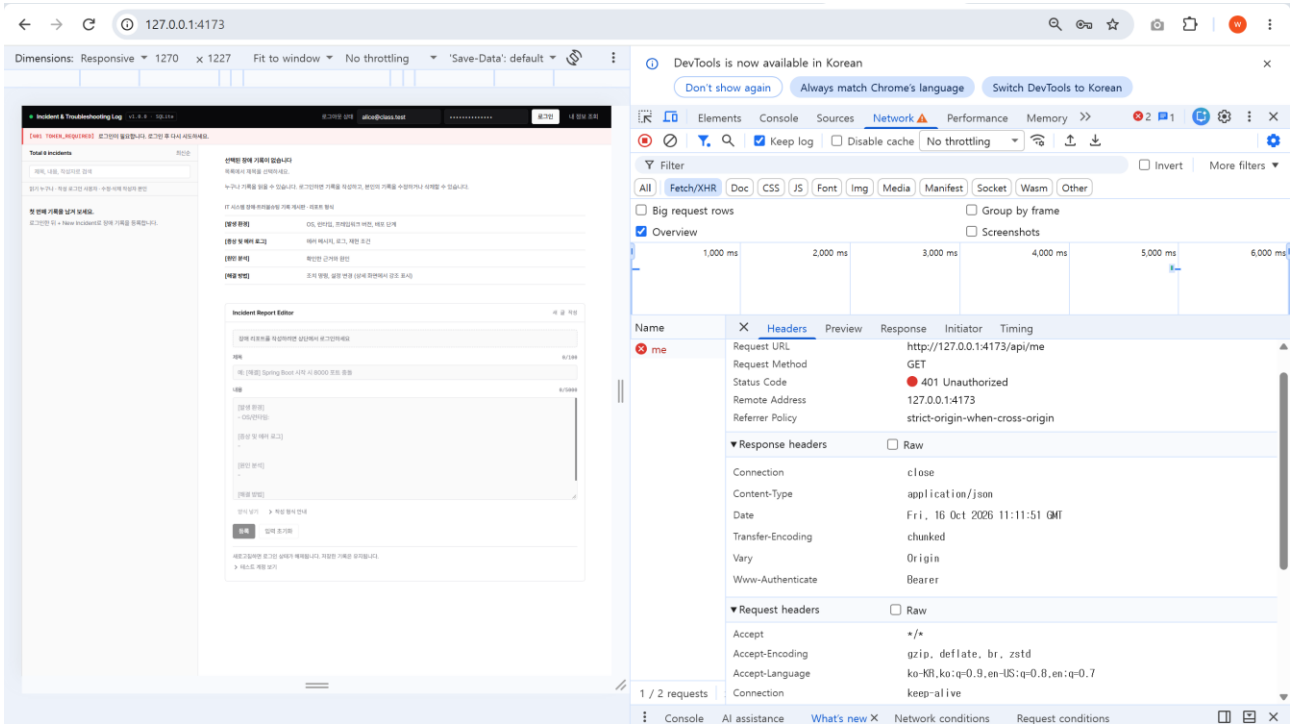


그림 3. T11 — 로그아웃 후 내 정보 요청. Authorization 헤더 없음, 응답 401, WWW-Authenticate: Bearer

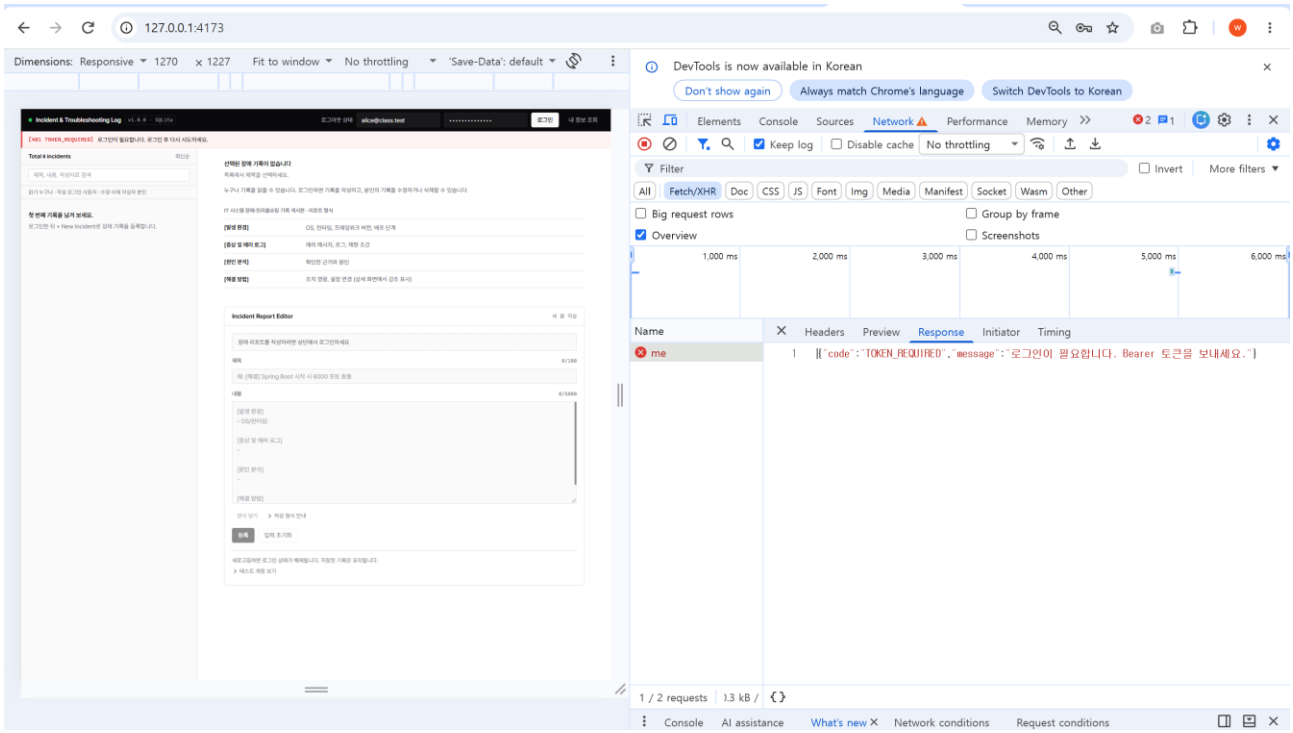


그림 4. T11 — 로그아웃 후 내 정보 응답 JSON 의 TOKEN_REQUIRED 확인

다른 작성자의 수정과 삭제

```
PS C:\Users\isyiw\Downloads\웹서비스설계\02_시작템플릿_및_제출양식\JWT-Assignment>py -u tools/check_api.py --mode final 2>&1 |
>>     Tee-Object -FilePath 'docs/evidence/manual/M11-check-api-final.log'
>>
>> $apiExitCode = $LASTEXITCODE
>> "ExitCode: $apiExitCode"
PASS unknown email
PASS no token me
PASS no token create
PASS login alice@class.test
PASS login bob@class.test
PASS Alice me
PASS Bob me
PASS create post
PASS public detail
PASS no token PUT
PASS Bob denied PUT
PASS failed request leaves data unchanged
PASS no token DELETE
PASS Bob denied DELETE
PASS failed request leaves data unchanged
PASS reject authorId
PASS reject userId
PASS input validation
PASS input validation
PASS input validation
PASS input validation
PASS tampered GET /me
PASS tampered POST /posts
PASS tampered PUT /posts/1
PASS tampered DELETE /posts/1
PASS failed request leaves data unchanged
PASS owner update
PASS create post
PASS Bob own update
PASS missing protected PUT
PASS missing protected DELETE
PASS delete owned test post
PASS deleted post missing
PASS delete owned test post
PASS deleted post missing
All 40 checks passed (final). UI and restart tests must be performed separately.
ExitCode: 0
```

그림 5. T07·T08 — Bob 의 Alice 글 수정·삭제 거부. 각각 403 FORBIDDEN, 거부 후 재조회 결과 일치

Bob 의 정상 토큰으로 Alice 글에 PUT 과 DELETE 요청을 보냈다. 공식 검사 로그의 Bob denied PUT 과 Bob denied DELETE 가 통과했다. 각 요청이 거부된 뒤 공개 조회 결과를 요청 전 객체와 비교해 전체 필드가 일치하는지 확인했다. 두 변경 요청의 응답은 각각 403 FORBIDDEN 이다.

토큰 변조와 만료

```
PASS failed request leaves data unchanged
PASS no token DELETE
PASS Bob denied DELETE
PASS failed request leaves data unchanged
PASS reject authorId
PASS reject userId
PASS input validation
PASS input validation
PASS input validation
PASS input validation
PASS tampered GET /me
PASS tampered POST /posts
PASS tampered PUT /posts/3
PASS tampered DELETE /posts/3
PASS failed request leaves data unchanged
PASS owner update
PASS create post
PASS Bob own update
PASS missing protected PUT
PASS missing protected DELETE
PASS login alice@class.test
Waiting 4 seconds for expiration
PASS expired GET /me
PASS expired POST /posts
PASS expired PUT /posts/3
PASS expired DELETE /posts/3
PASS failed request leaves data unchanged
PASS login alice@class.test
PASS login bob@class.test
PASS delete owned test post
PASS deleted post missing
PASS delete owned test post
PASS deleted post missing
All 48 checks passed (final). UI and restart tests must be performed separately.
ExitCode: 0
PS C:\Users\isiw\Downloads\웹서비스설계\02_시작템플릿_및_제출양식\JWT-Assignment>
```

그림 6. T09·T10 — 변조 요청 401 INVALID_TOKEN, 만료 요청 401 TOKEN_EXPIRED. 만료 포함 공식 검사 48 건 통과

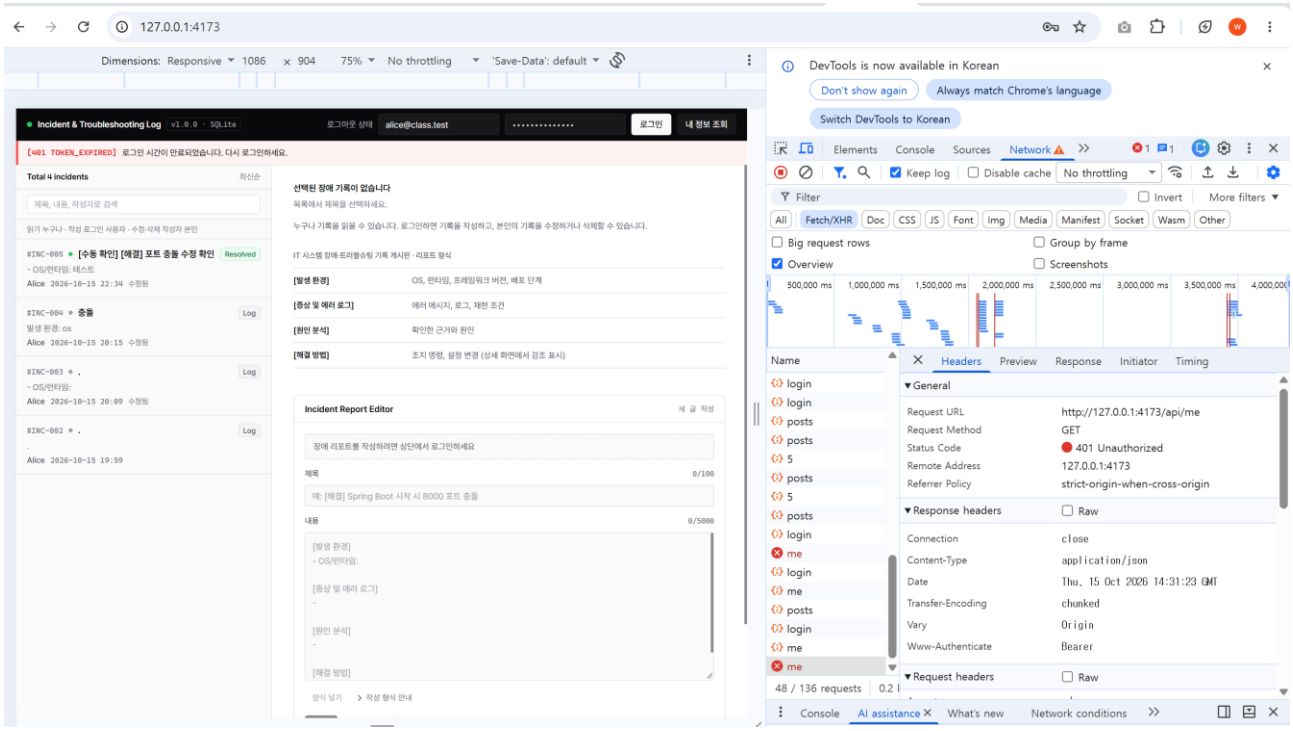


그림 7. T10 — 만료 토큰의 내 정보 요청. 401 TOKEN_EXPIRED, 만료 안내와 로그인 해제

자동 검사와 로컬 배포 증거

공식 검사 실행 명령은 다음과 같다. 일반 검사에는 TOKEN_TTL=90, 만료 검사에는 TOKEN_TTL=3 을 사용했다. M12 로그의 Waiting 4 seconds 는 응답 expiresIn 에 1 초를 더한 대기다. 시험 뒤 일반값을 복구했으며 TOKEN_TTL 은 90 이다.

```
py tools/check_api.py --mode final
py tools/check_api.py --mode final --expiry
```

일반 결과는 All 40 checks passed (final)., 만료 포함 결과는 All 48 checks passed (final).이다. 전체 출력은 M11·M12 의 .log 에 저장했다. 각각의 실행 캡처에 남은 종료 코드는 0.

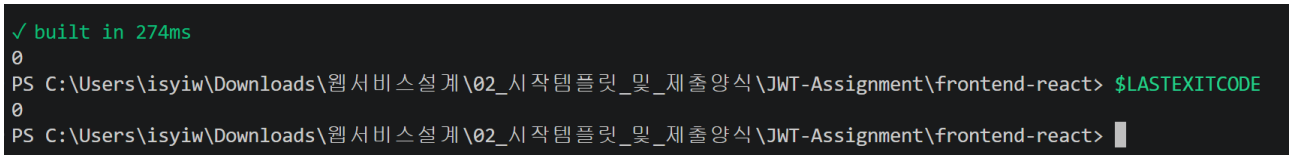


그림 8. 로컬 배포 확인 — 프론트엔드 빌드 시간 274ms, 종료 코드 0

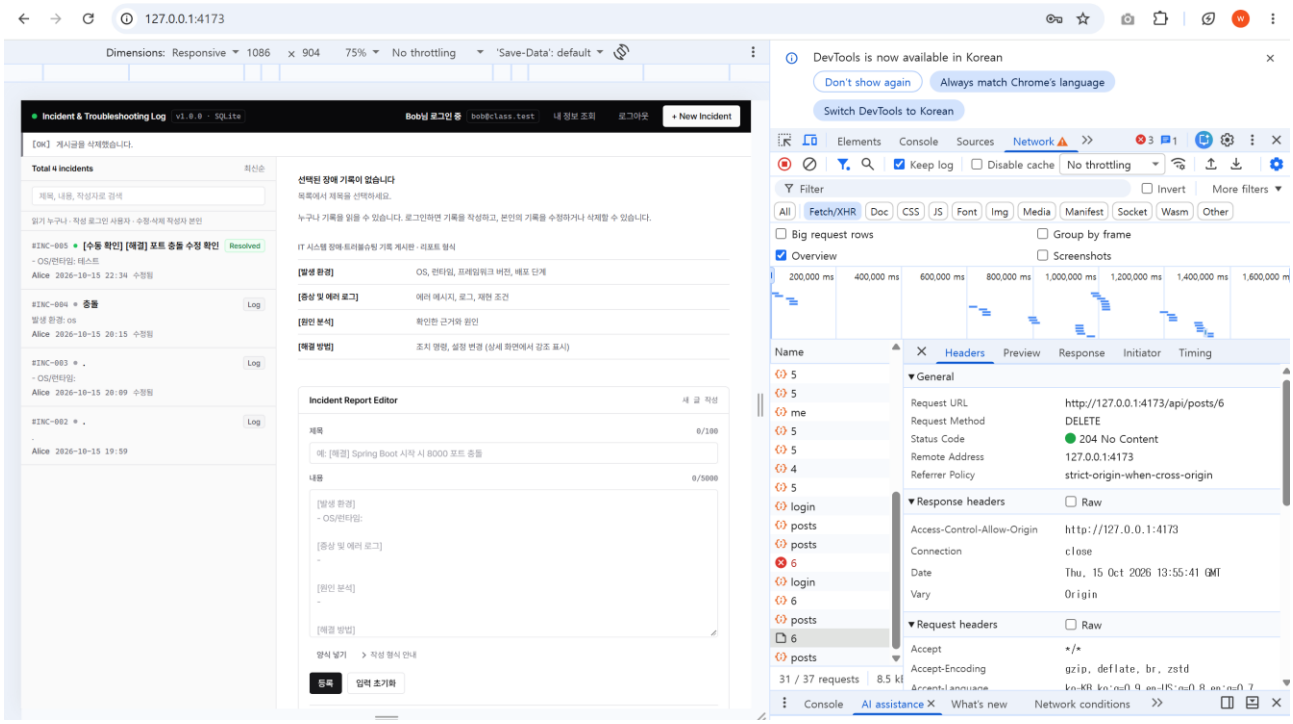


그림 9. T17 — Bob 본인 글 삭제 성공. DELETE /api/posts/6, 응답 204

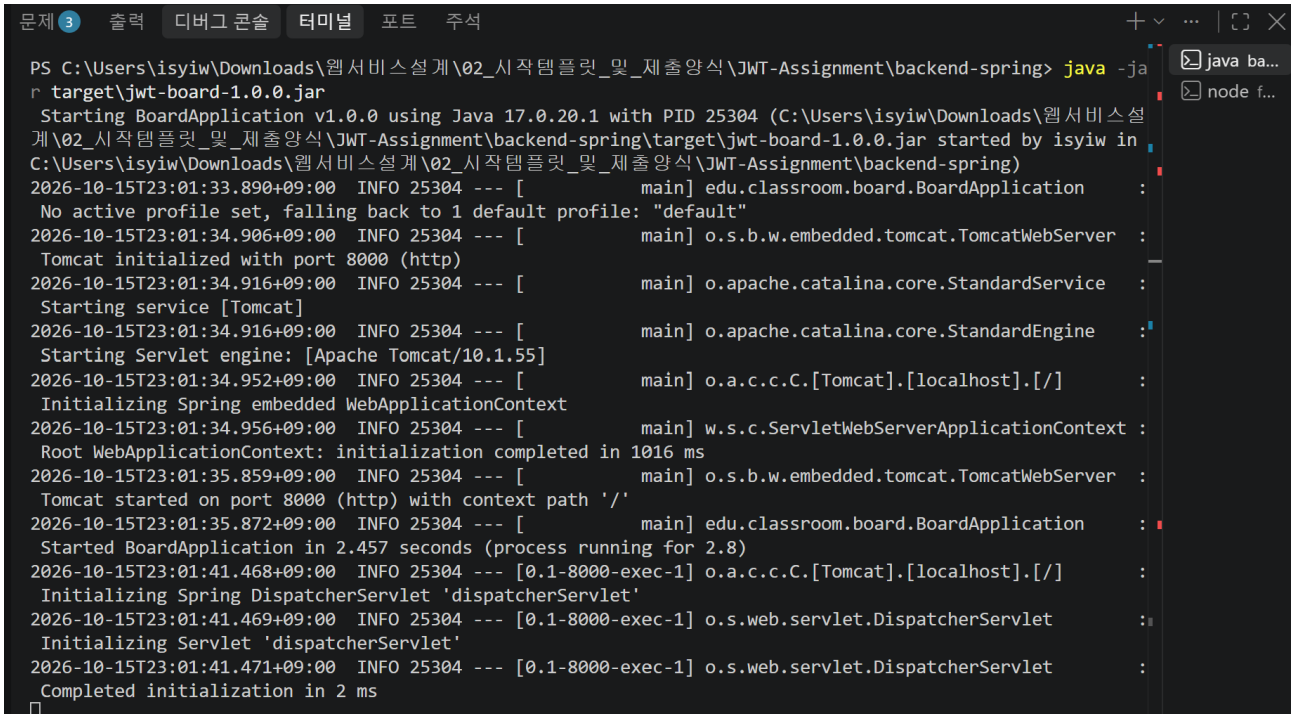


그림 10. T15 — 서버 재실행 로그. 8000 번 포트에서 정상 기동 확인

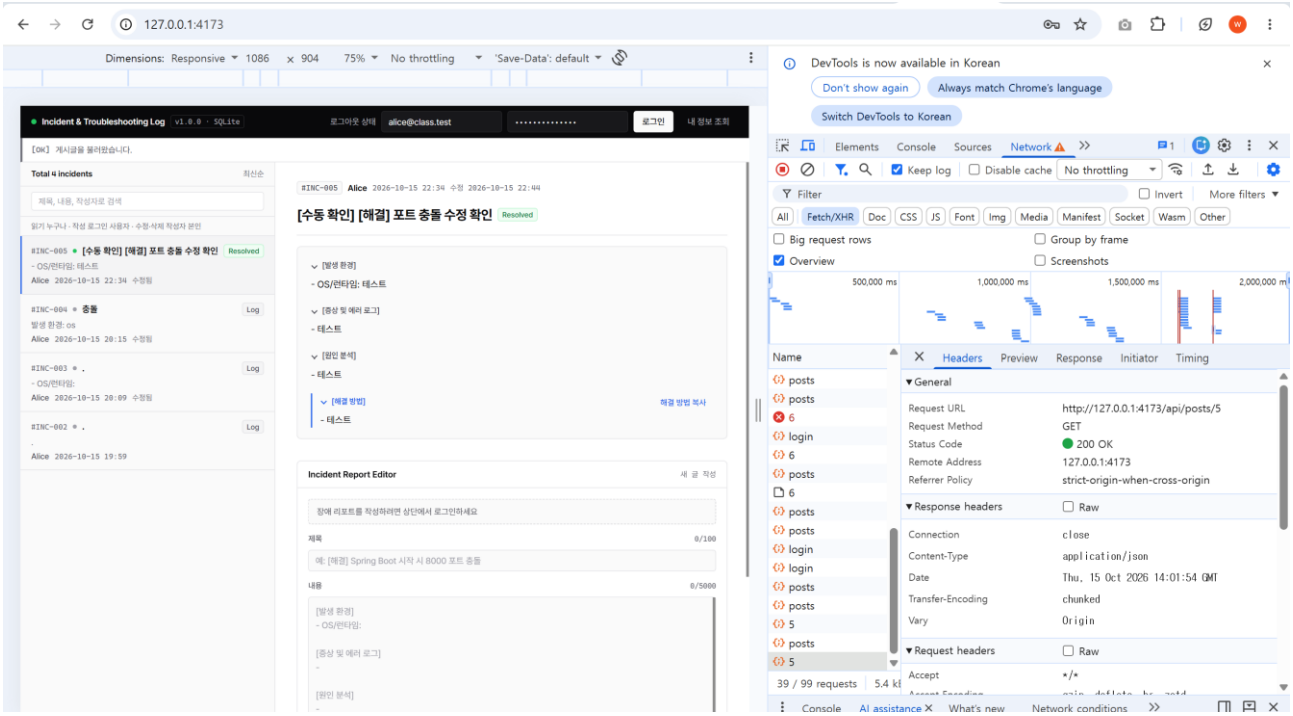


그림 11. T15 — 서버 재시작 후 4173 번 화면에서 기존 5 번 글 조회. 응답 200, 제목·본문·작성자 유지

AI 활용과 참고 자료

AI 사용 여부: 사용

도구와 모델	사용 목적	반영한 파일 또는 보고서 항목	반영 방식
Codex, 모델 미확인	JWT 발급·검증과 작성자 검사 구현, 프론트엔드 인증 연결, 오류 표시·반응형 수정, 문서 작성	AuthService.java, BoardController.java 의 fields(), frontend-react/src/api.js, main.jsx, style.css, README.md, 보고서	AI 가 작성·수정한 코드를 반영했다. 직접 실행한 테스트 결과와 캡처를 대조해 문서를 수정했다.
Claude Code, 모델 미확인	장애·트러블슈팅 게시판 화면 초안 작성	frontend-react/src/main.jsx, src/style.css, index.html, package.json, package-lock.json	화면 초안을 반영했다. 이후 Codex 의 오류 표시·반응형 수정 코드를 적용하고 직접 빌드와 화면을 확인했다.

대표 사례

대표 사례 1. JWT 발급·검증과 작성자 권한 검사

도구 / 날짜: Codex / 코드 작성 날짜 미기록. 직접 확인한 테스트 일자는 2026 년 10 월 15~16 일이다.

요청한 내용: 제공 템플릿의 미완성 인증을 수업 공지와 API 명세에 맞게 구현하도록 요청했다. 코드 수정과 직접 수행해야 할 테스트를 구분하도록 요청했다.

AI 가 제안한 내용: 64 자리 16 진수 비밀 키를 바이트로 변환해 HS256 서명에 사용하도록 제안했다. Bearer 헤더, 서명, 알고리즘, 만료, 필수 클레임과 계정 존재를 검사하도록 제안했다. 글 수정·삭제에서는 토큰의 계정 ID 와 저장된 작성자 ID 를 비교해 불일치 시 403 FORBIDDEN 을 반환하도록 제안했다.

실제 반영 위치: backend-spring/src/main/java/edu/classroom/board/AuthService.java 의 생성자, issueToken(), currentUserId(), verifiedUserId(), assertOwner()에 반영했다. BoardController.java 의 fields()에는 비밀번호 원문 길이 검사 수정을 반영했다.

내가 확인하고 수정한 내용: 비밀 키 누락·형식 오류·예시 키가 거부되는지 직접 확인했다. 정상 키를 복구한 뒤 로그인과 만료 검사를 수행했다. 원본 JSON 의 숫자형 exp 검사와 비밀번호 원문 길이 검사는 Codex 가 작성한 수정 코드를 반영한 부분이다. Users.java 의 PBKDF2 검증과 PostStore.java 의 CRUD 는 제공 코드를 유지했다.

검증 방법과 결과: T02·T03 에서 정상 로그인과 잘못된 계정을 확인했다. T07·T08 에서는 Bob 의 타인 글 수정·삭제 거부와 재조회 결과 일치를 확인했다. T09·T10 에서는 서명 변조와 실제 만료 요청을 검사했다. 증거는 M11-check-api-final.log 와 M12-check-api-expiry.log 이며, 변조는 401 INVALID_TOKEN, 만료는 401 TOKEN_EXPIRED, 작성자 불일치는 403 FORBIDDEN 이다.

대표 사례 2. 프론트엔드 토큰 관리와 오류 처리

도구 / 날짜: Codex / 코드 작성 날짜 미기록. 직접 확인한 테스트 일자는 2026 년 10 월 15~16 일이다.

요청한 내용: 로그인 응답의 토큰을 모듈 변수에 저장하고 API 요청 헤더에 첨부하도록 요청했다. 로그인 상태에 따른 버튼 표시와 HTTP 상태·JSON 오류 코드에 따른 알림을 연결하도록 요청했다.

AI 가 제안한 내용: session 에 토큰과 계정 정보를 저장하고 authorizationHeaders()에서 Bearer 헤더를 생성하도록 제안했다. 401 에서는 세션을 지우고 403 에서는 유지하도록 제안했다. 화면 알림에는 오류 객체의 status 와 code 를 사용하도록 제안했다.

실제 반영 위치: frontend-react/src/api.js 의 login(), authorizationHeaders(), request(), clearSession(), canEdit()에 반영했다. frontend-react/src/main.jsx 의 run(), save(), 로그인·로그아웃 이벤트에도 반영했다.

내가 확인하고 수정한 내용: Codex 의 토큰 저장·전송 코드를 반영했다. 알림은 문자열에서 HTTP 상태를 추측하는 대신 e.status 와 e.code 를 표시하도록 수정한 코드를 적용했다. 제공 코드의 204 빈 본문 처리와 저장 실패 시 입력 유지 동작은 남겼다. 403 이후 로그인 유지는 직접 캡처한 결과와 구분해 request()의 조건문으로 확인했다.

검증 방법과 결과: T11 의 로그아웃 후 요청은 M13-1-logout-headers.png 와 M13-1-logout-response.png 에 기록했다. 요청에 Authorization 헤더가 없으며 응답은 401 TOKEN_REQUIRED 이다. M03-input-400.png 에서 400 BAD_INPUT 이후 입력 유지를 확인했다. M08-expired-401.png 에서는 만료 안내와 로그인 해제를 확인했다. 만료 응답 처리 후 변수 상태는 session = { accessToken: "", user: null }이다.

대표 사례 3. 게시판 화면 구성과 반응형 수정

도구 / 날짜: Claude Code·Codex / 코드 작성 날짜 미기록. 직접 화면을 확인한 날짜는 2026 년 10 월 15 일이다.

요청한 내용: 장애 기록을 목록과 상세 화면으로 나누고 발생 환경·증상·원인·해결 방법을 구분해 표시하도록 요청했다. 화면 개편 후에는 수정할 부분을 확인하도록 요청했다.

AI 가 제안한 내용: Claude Code 는 목록·상세 분할, 본문 구역 표시, 코드 블록, 검색과 해결 방법 복사 기능을 포함한 화면 초안을 작성했다. 이후 Codex 는 상단 바의 줄바꿈 기준을 1023px 이하로 조정하도록 제안했다.

실제 반영 위치: frontend-react/src/main.jsx, src/style.css, index.html, package.json, package-lock.json 에 화면 초안을 반영했다. 상단 바의 줄바꿈 수정은 frontend-react/src/style.css 에 반영했다.

내가 확인하고 수정한 내용: Claude Code 의 화면 초안을 반영한 뒤 Codex 의 후속 수정 코드를 적용했다. 상단 바 줄바꿈은 1023px 이하, 목록·상세의 세로 배치는 899px 이하로 구분했다. 직접 너비 900px 과 390px 에서 화면 배치를 확인했다.

검증 방법과 결과: M09-responsive-900.png 에서 900px 화면의 상단 바 줄바꿈을 확인했다. M10-responsive-mobile.png 에서 390px 화면의 목록·상세 세로 배치를 확인했다. 프론트엔드 빌드는 M00-build.png 에 기록했으며, 종료 코드는 0 이다.

참고 자료

자료 제목과 URL	사용한 위치	반영 내용 및 출처 표시
docs/01_과제공지.md	구현 범위, 보고서 01·04 절	필수 기능, JWT 조건, 제출물과 기본 포트의 기준으로 사용했다.
docs/02_API 명세.md	BoardController.java, AuthService.java, frontend-react/src/api.js	요청 경로·필드, HTTP 상태, JSON 오류 코드와 응답 헤더를 대조했다.
docs/03_구현체크리스트.md	인증·권한 구현 확인	백엔드와 프론트엔드의 구현 항목을 확인했다.
docs/04_보고서양식.docx, docs/04_보고서양식.md	보고서 01~06 절	절 구성, 코드 발췌, 테스트 기록과 AI 활용 출처 형식을 따랐다.
docs/05_테스트시나리오.md	보고서 04 절	T01~T17 의 절차·기대 응답과 실제 결과를 대조했다.
docs/07_로컬실행안내.md	README.md, 로컬 실행 기록	설치·환경변수·빌드·preview·JAR 실행과 SQLite 경로를 정리했다.
tools/check_api.py	일반 검사·만료 검사	제공 파일을 유지한 채 직접 실행했다. 결과는 M11·M12 로그와 캡처에 기록했다.
backend-spring/src/main/, frontend-react/src/	보고서 02·03·06 절	실제 함수·조건문·변수와 코드 발췌를 대조했다.
docs/evidence/manual/	보고서 04 절	로그인, 요청 헤더, HTTP 응답, 빌드와 서버 재시작 결과를 기록했다.

이해도 확인과 회고

1. 요청 본문의 authorId 를 믿으면 어떤 문제가 생기며, 내 코드는 어떻게 막는가?

요청 본문의 authorId 를 작성자 ID 로 사용하면 Bob 이 authorId: 1 을 보내 Alice 이름으로 글을 등록할 수 있다. BoardController.java 의 create()는 auth.currentUserId(req)로 확인한 계정 ID 를 store.create()에 전달한다. 작성자는 이 값으로 결정한다. 요청 본문은 fields()에서 title 과 content 만 허용한다. authorId 나 userId 를 추가하면 DB 저장 전에 거부하며, 응답은 400 BAD_INPUT 이다.

2. 수정 버튼을 숨기는 것만으로 충분하지 않은 이유는 무엇이며, 서버의 어떤 함수가 권한을 검사하는가?

frontend-react/src/api.js 의 canEdit()는 로그인 계정의 ID 와 post.authorId 가 일치하는지 확인한다. main.jsx 는 이 결과에 따라 수정·삭제 버튼을 표시한다. 버튼이 없어도 API 클라이언트에서 PUT 이나 DELETE 요청을 직접 보낼 수 있다. 서버의 BoardController.java 는 update()와 delete()에서 인증 후 글을 조회한다. 이어서 AuthService.java 의 assertOwner()가 검증된 계정 ID 와 DB 에서 조회한 p.authorId()를 비교한다. 두 값이 다르면 DB 를 변경하기 전에 거부하며, 응답은 403 FORBIDDEN 이다.

3. JWT decode 와 verify 의 차이는 무엇이며, 내 코드는 어떤 검증을 수행하는가?

decode 는 토큰의 헤더와 본문을 해석해 내용을 읽는 작업이다. 내용을 읽는 것만으로 서명이나 클레임의 유효성을 확인할 수는 없다. 내 AuthService.java 는 parser.parseSignedClaims()로 서명을 검증하며 HS256 만 허용한다. iss 는 설정된 발급자와 일치해야 하고, aud 에는 설정된 대상이 포함되어야 한다. exp 의 존재·숫자형·만료 여부를 확인한다. sub 는 양의 정수를 나타내는 문자열이어야 하며, long 으로 변환한 ID 에 해당하는 계정이 실제로 존재해야 한다. 헤더 누락·형식 오류는 401 TOKEN_REQUIRED, 서명·알고리즘·필수 클레임·계정 검증 실패는 401 INVALID_TOKEN 이다.

만료 예외가 발생해도 verifiedUserId(e.getClaims())로 필수 클레임과 계정 존재를 다시 검사한다. 나머지 조건을 통과한 만료 토큰의 응답은 401 TOKEN_EXPIRED 이다.

4. 로그아웃, 토큰 만료, 새로고침은 각각 무엇을 바꾸는가? 이미 복사된 토큰은 어떻게 되는가?

로그아웃은 frontend-react/src/api.js 의 clearSession()을 호출한다. main.jsx 의 로그아웃 이벤트는 화면의 계정·프로필·수정 상태도 초기화한다. 이 탭의 변수 상태는 session = { accessToken: "", user: null }이다.

토큰 만료 시각이 지났다고 브라우저 상태가 즉시 바뀌지는 않는다. 만료 토큰으로 보호 API 를 요청하면 서버가 401 TOKEN_EXPIRED 를 반환한다. api.js 의 request()가 clearSession()을 호출한 뒤 main.jsx 의 run()이 화면 상태를 갱신한다. 처리 후 변수 상태는 session = { accessToken: "", user: null }이다.

새로고침하면 api.js 모듈을 다시 불러오므로 로그인 정보가 초기화된다. SQLite 에 저장된 게시글은 삭제되지 않는다. M05-refresh.png 에서 로그아웃 상태와 기존 글 표시를 확인했으며, 글 조회 응답은 200 이다.

서버에는 로그인 세션이나 토큰 폐기 목록을 저장하지 않는다. 로그아웃도 서버에 토큰 폐기 요청을 보내지 않는다. 따라서 이미 외부로 복사한 JWT 는 서명 키·클레임·계정이 계속 유효하면 exp 전까지 인증에 사용할 수 있다. 다른 검증 조건을 통과하더라도 만료 시각이 지나면 응답은 401 TOKEN_EXPIRED 이다.

5. 가장 어려웠던 오류 한 가지와 원인 확인·수정·재검증 과정을 설명하라.

화면 개편 후 너비 900px 에서 상단 바의 버튼이 화면 밖으로 나오는 문제를 확인했다. 상단 바의 줄바꿈과 목록·상세 화면의 세로 배치를 별도로 처리하도록 Codex 에 수정을 요청했다. 수정 코드를 반영한 frontend-react/src/style.css 는 1023px 이하에서 .topbar, .topbar-right, .auth-bar 에 flex-wrap: wrap 을 적용한다. 목록·상세의 세로 배치는 899px 이하에서 적용한다. 수정 후 직접 900px 과 390px 화면을 확인했다. M09-responsive-900.png 에는 상단 바 줄바꿈을, M10-responsive-mobile.png 에는 목록·상세의 세로 배치를 기록했다. 프론트엔드 빌드 결과는 M00-build.png 에 기록했으며 종료 코드는 0 이다.

현재 남은 문제와 다음에 개선할 점: 없음

제출 확인: [ ] 실제 코드와 설명 일치 [ ] 테스트 직접 수행 [ ] AI 활용 및 출처 기록 [ ] 비밀 키와 토큰 제거

GitHub 확인: [ ] 루트 README 작성 [ ] 보고서 PDF 와 증거 업로드 [ ] README 문서 링크 확인 [ ] 교수자 접근 가능 [ ] 저장소 URL 과 커밋 SHA 제출